MODULE 10 · DOMAIN 1 - PLAN AND MANAGE AN AZURE AI SOLUTION

Responsible AI instrumentation and governance

Safety evaluators, red teaming, audit trails, provenance, approval workflows, oversight modes and tool-access controls.

DOMAIN 1 - Plan and manage WEIGHT 25-30% MODULE 10 of 39

admin@sthithapragna.com

Guardrails stop harm in the moment. Governance **measures** risk, **proves** what happened, and **limits** what an agent may do alone.

Three skills, three sets of tools

SKILL	QUESTION IT ANSWERS	TOOLS
Instrument	How risky is the system?	Safety evaluators, red teaming, evaluator reasons
Audit	What happened, and who allowed it?	Traces, provenance metadata, logged approvals
Govern	What may the agent do alone?	Oversight modes, tool allow lists, fleet policy

ON THE EXAM

Most scenarios in this area ask for one of these three. Identify which question is being asked before choosing a tool.

Risk and safety evaluators

EVALUATOR	MEASURES
Hate and unfairness, sexual, violence, self-harm	Harmful content in responses
Protected material	Copyrighted content in responses
Indirect attack	Whether the system fell for instructions hidden in context
Code vulnerability	Security flaws in generated code
Ungrounded attributes	Invented claims about a person, inferred from the conversation
Prohibited actions, sensitive data leakage	Agent-specific risks: forbidden actions, exposed data

ON THE EXAM

Microsoft's guidance: add the four content evaluators to every application, then add the rest to match its risks.

Evaluators explain their scores

- Each result includes a **score**, a **pass or fail label**, the **threshold** used, and a **reason**.
- The reason says why, such as 'the response refuses to provide harmful content'.
- Groundedness results can point to **which part** of a response was unsupported.
- Reasons turn a failing score into a fix: read them before changing prompts or models.
- Evaluators are models too. Sample and review their reasons, especially for high-stakes decisions.

> ON THE EXAM
>
> A score says how bad. The reason says what to change. Use the reason to triage failures quickly.

Safety evaluation or red teaming?

SAFETY EVALUATION

How does it behave on this data?

- Scores responses to a dataset or live traffic
- Measures ordinary and known-risky inputs
- Tracks safety over time and releases

RED TEAMING

Can an attacker break it?

- Generates adversarial attacks automatically
- Disguises requests to slip past defences
- Reports how often attacks succeed

THE TIEBREAKER

Passing a safety evaluation says nothing about determined attackers. Resistance to disguised attacks needs red teaming.

Automated red teaming in Foundry

- Built on **PyRIT**, Microsoft's open-source red teaming framework.
- Starts from attack objectives for each risk category, such as violence or hate.
- **Attack strategies** disguise them: Base64 encoding, flipped text, gradual escalation over turns.
- Key metric: **Attack Success Rate**, successful attacks divided by total attacks. Lower is better.
- Produces a scorecard by risk and attack complexity. Billed as safety evaluation usage.

> ON THE EXAM
>
> A plain harmful request is often refused. Attack strategies test whether the same request succeeds in disguise.

Trace logging as an audit trail

- Traces record each run: model calls, **tool calls with their arguments**, results and errors.
- Built on **OpenTelemetry**, stored in Application Insights. External agents can send traces too.
- Microsoft's advice for MCP tools: **log approvals and tool calls** for auditing.
- Traces can contain prompts and personal data. Restrict access with roles, and set retention deliberately.

> THE SIGNAL
>
> 'What did the agent do, and with what data?' is answered by traces, not by metrics or evaluation scores.

Provenance metadata for generated media

- Images from Azure OpenAI image models carry **Content Credentials** automatically. No setup needed.
- Based on the open **C2PA** standard: a manifest describing the content's origin.
- The manifest is **cryptographically signed** by a certificate that traces back to Azure OpenAI.
- Anyone can check it with a Content Credentials verification tool.
- Metadata can be stripped by some editing or upload tools. Microsoft also embeds invisible watermarks.

> ON THE EXAM
>
> 'Third parties must be able to verify the image is AI-generated' is a provenance requirement. Keep credentials intact when publishing.

Oversight modes: how much may it do alone?

MODE	HUMAN ROLE	SUITS
Autonomous	Reviews results later	Read-only, low-risk tasks
Approve high-risk actions	Approves writes and payments	Most production agents
Approve every action	Approves each tool call	New or high-stakes agents
Monitored autonomy	Watches alerts and trends	Mature, well-traced agents

THE TIEBREAKER

Match oversight to consequence, not to tool count. One irreversible tool deserves approval even if ten others don't.

Approval workflows

- An MCP tool can be set to **always require approval**, or never.
- When approval is needed, the run **pauses** and returns the pending tool call.
- Your app shows a human the **tool name and arguments**, then sends back approve or deny.
- Microsoft Agent Framework function tools can require approval in the same way.
- Approval decides whether a call proceeds. Roles still decide whether it can succeed.

> ON THE EXAM
>
> Microsoft recommends approval for tools that write data or change resources, and logging every approval.

Constraints and tool-access controls

- **allowed_tools:** an allow list of the only tools an agent may call on an MCP server.
- **Identity and roles:** separate agent identities, and agent-scope roles for who may call an agent.
- **Task adherence (preview):** a guardrail control that flags an agent drifting from its instructions.
- **Egress controls (preview):** limit which outbound destinations a hosted agent can reach.
- Treat tool descriptions and results from remote MCP servers as **untrusted input**.

> ON THE EXAM
>
> A tool the agent cannot see cannot be called, whatever an injected instruction says.

Instructions are the job description. Tool access is the **keycard**. Approval is the **manager's signature**. Never put a lock in the job description.

Foundry Control Plane

- One view of the whole **agent fleet**: health, cost, compliance and prohibited behaviours.
- The **Compliance** pane applies guardrail policies across model deployments.
- Integrates **Azure Policy**, **Defender** and **Microsoft Purview** signals.
- **Versioned policies** and assignment tracking support audit. Non-compliant assets can be bulk-remediated.
- Agents built elsewhere can be registered, and send OpenTelemetry traces.

> ON THE EXAM
>
> Creating or editing guardrail policies here needs Owner or Resource Policy Contributor on the subscription or resource group.

The governance lifecycle

01
Red team
Find weaknesses before release.

02
Evaluate
Score safety on datasets.

03
Guardrail
Block risks in the moment.

04
Constrain
Allow lists and approvals.

05
Audit
Trace calls and approvals.

06
Re-test
Scheduled red teaming and evaluation.

ON THE EXAM

Governance is a loop, not a launch checklist. Models, prompts and attackers all change after release.

A bank's customer chatbot passes its safety evaluation on a curated test dataset. Guardrails are configured.

The security team now wants to know how well it resists users who disguise harmful requests with encodings or gradual escalation, with a metric to compare between releases.

What should the team do?

A Set all four harm category thresholds to Low on input and output.

B Turn on continuous evaluation for a sample of production traffic.

C Run the AI Red Teaming Agent and track attack success rate.

D Add the Prompt Shields user prompt attacks control on input.

◆ PAUSE AND DECIDE

What should the team do?

A All thresholds to Low.

A mitigation that blocks more, not a measurement. It gives no resistance metric.

B Continuous evaluation on traffic.

Measures ordinary live traffic, not deliberate, disguised attacks.

C AI Red Teaming Agent, tracking ASR.

Generates disguised attacks and reports a comparable success rate per release.

D Prompt Shields on input.

Useful defence, but again a control, not a way to measure resistance.

THE SIGNAL

'Resists disguised attacks' plus 'a metric to compare releases' is red teaming and attack success rate.

A procurement agent uses two MCP servers. One exposes a tool that places purchase orders; the other exposes price lookups from the supplier catalogue.

Finance requires a person to approve every order before it is placed. Price lookups must run instantly, without waiting for anyone.

How should the team configure the agent?

A Always require approval on the order server, and never on the price server.

B Add an instruction telling the agent to ask for confirmation before ordering.

C Always require approval on both servers, so nothing runs without a person.

D Give the agent's callers the Foundry Agent Consumer role at agent scope.

◆ PAUSE AND DECIDE

How should the team configure the agent?

A Approval on orders only.

Every order pauses for a human, while read-only lookups stay instant.

B An instruction to ask first.

A job description, not a lock. An injection or a mistake can skip it.

C Approval on both servers.

Meets the order rule, but breaks the requirement that lookups run instantly.

D Agent Consumer role for callers.

Controls who may call the agent, not what the agent may do unapproved.

THE TIEBREAKER

Match oversight to consequence: the irreversible action gets a signature, the read-only one doesn't.

> A support agent connects to a company MCP server that exposes forty tools, including delete_customer and export_all_records.
>
> The agent only needs read_customer and create_ticket. Security insists it must be unable to call anything else, even if an injected instruction tells it to.

What should the team configure?

A Instructions telling the agent to use only read_customer and create_ticket.

B Approval required on all forty tools exposed by the company MCP server.

C An indirect attack control on tool responses, set to annotate and block.

D An allowed_tools list containing only read_customer and create_ticket.

◆ PAUSE AND DECIDE

What should the team configure?

A Instructions naming two tools.

The tools remain callable. An injected instruction can override the job description.

B Approval on all forty tools.

The dangerous tools stay callable, relying on a human never approving by mistake.

C Indirect attack control.

Helps catch injections, but doesn't remove the dangerous tools if one slips through.

D allowed_tools with two entries.

The other 38 tools can't be called at all, whatever any instruction says.

THE SIGNAL

'Unable to call', not 'unlikely to call'. Only removing the door from the keycard achieves that.

> A marketing team publishes images generated with an Azure OpenAI image model. New regulation requires that third parties can verify the images are AI-generated.
>
> Today the team adds 'AI-generated' to captions, but captions are often lost when images are shared.

What should the team rely on?

A. A database table recording the prompt used for every generated image.

B. Content Credentials attached automatically, kept intact.

C. A visible 'AI' badge added to a corner of every image before publishing.

D. Application Insights traces that log each image generation request.

◆ PAUSE AND DECIDE

What should the team rely on?

A. Database of prompts.
An internal record. Third parties can't see it or verify anything with it.

B. Content Credentials, kept intact.
A signed C2PA manifest travels with the image and anyone can verify it.

C. Visible badge.
Easily cropped out, and not cryptographically verifiable by anyone.

D. Application Insights traces.
Internal telemetry. Useful for your audit, invisible to third parties.

THE SIGNAL

'Third parties can verify' rules out every internal record. Verification needs signed metadata that travels with the file.

Governance in five lines

- **Instrument, audit, govern:** measure risk, prove what happened, limit autonomy.
- **Evaluation** scores behaviour on data. **Red teaming** tests disguised attacks, measured by ASR.
- **Traces** show what the agent did. **Content Credentials** prove where media came from.
- **Never put a lock in the job description.** allowed_tools is the keycard; approval is the signature.
- **Match oversight to consequence.** Control Plane governs the whole fleet.

> ON THE EXAM
>
> That completes Domain 1. Next, module 11 opens Domain 2: connecting an application to a Foundry project.